TryHackMe – Neighbour Room Write-up

Challenge Link	Neighbour Room
Created By	Adham Ahmad
Date	2026-10-16

Scenario:

Check out our new cloud service, Authentication Anywhere -- log in from anywhere you would like! Users can enter their username and password, for a totally secure login process! You definitely wouldn't be able to find any secrets that other people have in their profile, right?

So, first thing I did was a Nmap scan to see what ports are open:

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nmap 10.49.166.61
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-16 06:25 -0400
Nmap scan report for 10.49.166.61
Host is up (0.11s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http

Nmap done: 1 IP address (1 host up) scanned in 2.76 seconds
```

As in the pic, it appers that there is a website (port 80), so we need to check it out.

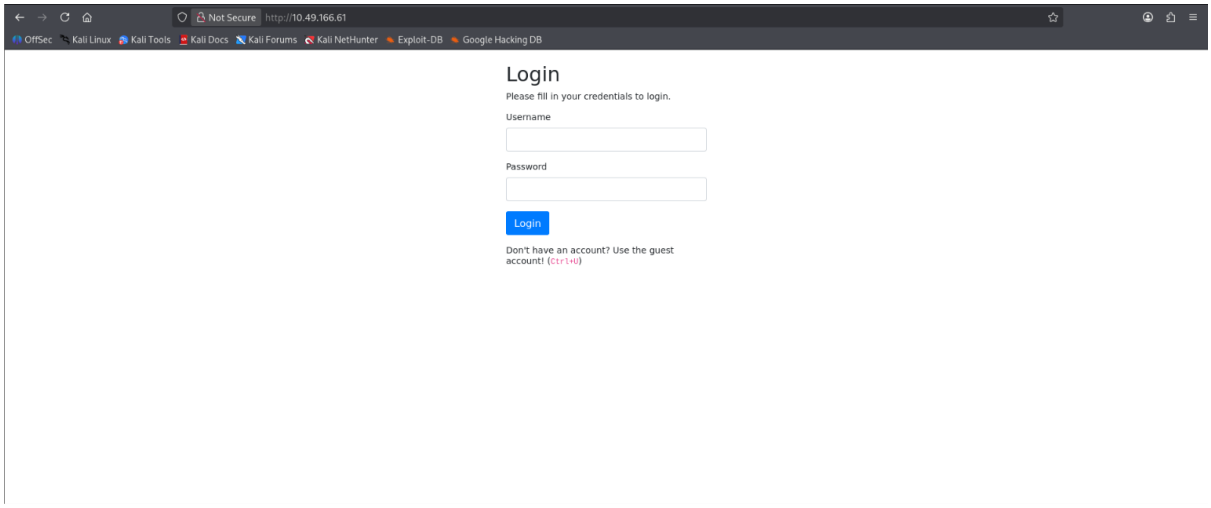
But before that lets Perform a directory and file enumeration using Feroxbuster to check if there are any hidden pages on the website:

```
┌──(kali㉿kali)-[/usr/bin]
└─$ feroxbuster -u http://10.49.166.61

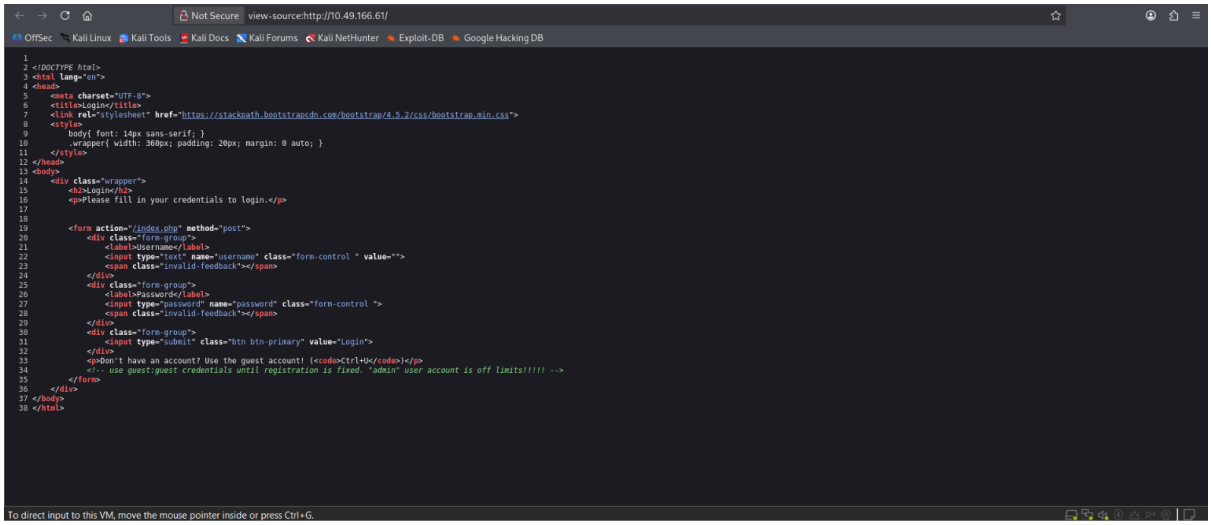
 ___  ___  __   __     __      __         __   ___
|__  |__  |__) |__) | /  `    /  \ \_/ | |  \ |__
|    |___ |  \ |  \ | \__,    \__/ / \ | |__/ |___
by Ben "epi" Risher 😊                 ver: 2.13.1
──────────────────────────┬──────────────────────
 🎯 Target Url            │ http://10.49.166.61/
 🚩 In-Scope Url          │ 10.49.166.61
 🚀 Threads               │ 50
 📖 Wordlist              │ /usr/share/feroxbuster/raft-medium-directories.txt
 👌 Status Codes          │ All Status Codes!
 💥 Timeout (secs)        │ 7
 🦡 User-Agent            │ feroxbuster/2.13.1
 💉 Config File           │ /etc/feroxbuster/ferox-config.toml
 🔎 Extract Links         │ true
 🏁 HTTP methods          │ [GET]
 🔃 Recursion Depth       │ 4
──────────────────────────┴──────────────────────
 🏁  Press [ENTER] to use the Scan Management Menu™
──────────────────────────────────────────────────
403      GET        9l       28w      277c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
404      GET        9l       31w      274c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
301      GET        9l       28w      313c http://10.49.166.61/assets ⇒ http://10.49.166.61/assets/
301      GET        9l       28w      309c http://10.49.166.61/db ⇒ http://10.49.166.61/db/
200      GET       38l      101w     1357c http://10.49.166.61/index.php
200      GET       38l      101w     1357c http://10.49.166.61/
301      GET        9l       28w      316c http://10.49.166.61/assets/js ⇒ http://10.49.166.61/assets/js/
301      GET        9l       28w      317c http://10.49.166.61/assets/css ⇒ http://10.49.166.61/assets/css/
[####################] - 3m    150010/150010  0s      found:6       errors:914
[####################] - 3m     30000/30000   198/s   http://10.49.166.61/
[####################] - 3m     30000/30000   200/s   http://10.49.166.61/assets/
[####################] - 2m     30000/30000   203/s   http://10.49.166.61/db/
[####################] - 2m     30000/30000   205/s   http://10.49.166.61/assets/js/
[####################] - 2m     30000/30000   208/s   http://10.49.166.61/assets/css/
```

It doesn't look like something useful here.

Let's check the website by pasting the IP in the browser.

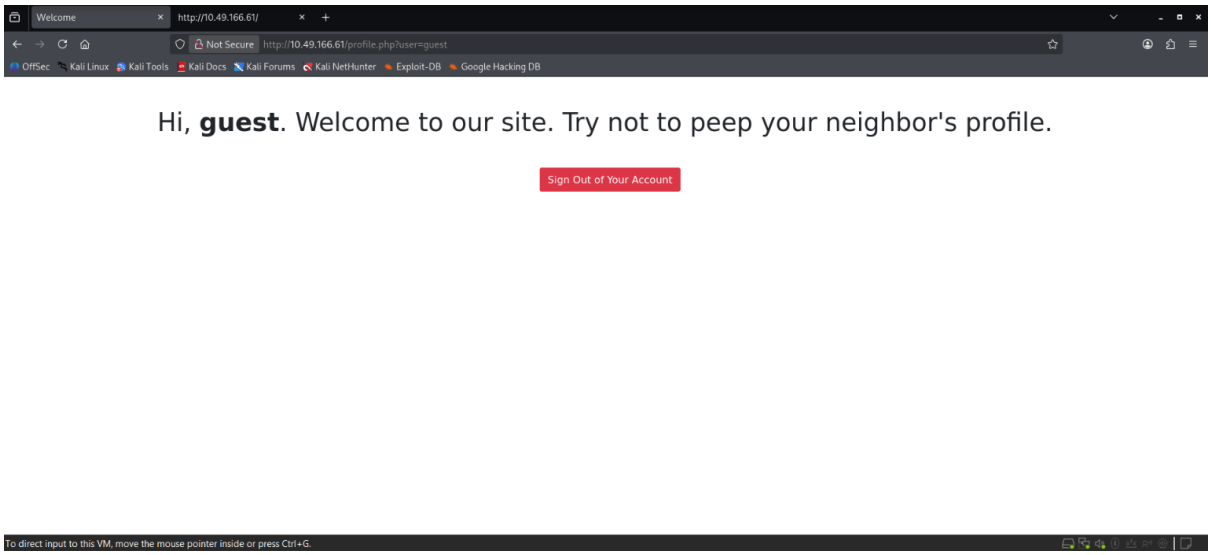


So it is a login page and there is a massage says "Don't have an account? Use the guest account! (Ctrl+U)", So we go to the View page or Ctrl+U.



As we see in the green sentence "<!-- use guest:guest credentials until registration is fixed. "admin" user account is off limits!!!!! -->" So we have a Guest Account we can use to login with. And the message mention an admin user account. We should keep this in mind; we might use it later, or it could be the objective.

Let’s try login using the guest account:

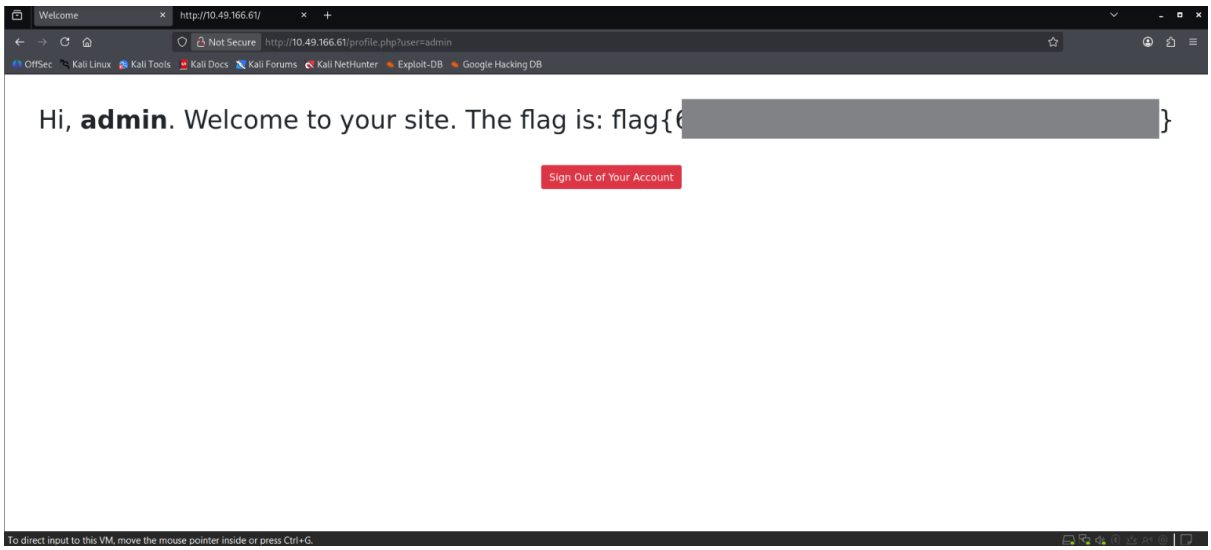


So, the first thing that I noted is the URL http://10.49.166.61/profile.php?user=guest

As we can see that it says profile and then user = TheUserName we login with.

so it displays the user profile based on the parameter so maybe if we changed the parameter for another user name we could access their profile

So lets try admin instead of guest in the URL
http://10.49.166.61/profile.php?user=admin and see what will happen:



finally we got the flag now we can submit it and end the challenge.

This demonstrated an Insecure Direct Object Reference (IDOR) vulnerability, where the application allowed access to another user's profile without properly checking authorization.

Thanks.